

AI Code Review 完整报告

基础信息

- 审查工具: Trae AI Code Review
- 审查日期: 2026-07-18
- 项目名称: 在线投票系统
- 技术栈: PHP + MySQL + HTML/CSS/JavaScript
- 代码规模: 18 个 API 接口文件、9 个前端页面、3 个全局配置文件
- 审查文件范围:
`create\_poll.php`、`vote.php`、`login.php`、`db.php`、`logger.php`、
`admin\_polls.php`、`get\_polls.php`、`admin\_users.php`、`create\_poll.js`

一、整体代码质量评分

评估维度	星级评分	简要说明
安全性	★ ★ ★ ★	使用 PDO 预处理语句、密码加密存储；但存在敏感信息泄露、事务缺失高危隐患
代码规范	★ ★ ★	模块划分清晰，缺少统一错误处理、公共响应封装、复用工具类
性能表现	★ ★ ★	基础 SQL 无语法错误，存在 N+1 循环查询拖慢接口速度
可维护性	★ ★ ★	功能拆分独立，API 返回格式不统一、配套文档缺失

二、问题分级总览

- ①高危严重问题（必须立刻修复）
共 2 项，涉及数据安全、信息泄露，上线必整改
- 1. admin_users.php 错误返回携带完整 Session，泄露用户敏感凭证
 - 2. vote.php 投票扣票/新增记录无数据库事务，极易出现数据不一致
- ②中等优化问题（迭代内完成整改）
共 4 项，功能缺失、逻辑冲突、性能损耗、不规范终止程序
- 1. create_poll.php 登录会话校验逻辑不统一，管理员身份判断存在漏洞
 - 2. admin_polls.php 后台创建投票不支持图片选项存储
 - 3. get_polls.php 循环查询产生 N+1 数据库性能问题
 - 4. db.php 数据库异常使用 die()终止，不符合工程化错误处理规范
- ③低危优化建议（长期重构完善）
共 4 项，工程化、代码复用、规范统一类优化
- 1. logger.php 日志无自动清理轮转，长期运行占用磁盘
 - 2. 全项目 API 返回结构体不统一，前端适配成本高

3. create_poll.js 前端重复 DOM 操作，无封装通用工具函数

4. env.php 环境变量读取缺少默认值类型校验

三、分项问题详细分析与优化方案

高危问题 1: admin_users.php 错误响应泄露 Session 敏感信息

文件位置: admin_users.php 第 8 行

问题描述: 无管理员权限时，返回 JSON 中直接输出完整`\$\_SESSION`数组，会泄露登录凭证、用户 ID 等隐私数据。

原代码:

```
```php
echo json_encode(['status' => 'error', 'message' => '无权限访问', 'session' =>
$_SESSION]);
```
```

优化后代码:

```
```php
echo json_encode(['status' => 'error', 'message' => '无权限访问']);
```
```

高危问题 2: vote.php 投票逻辑缺少事务保障

文件位置: vote.php 29~64 行

问题描述: 投票同时执行「新增投票记录」「更新选项票数」两步操作，无事务；若中途报错会出现票数和记录对不上的数据错乱。

优化完整代码示例:

```
```php
try {
 $db = getDB();
 $db->beginTransaction(); // 开启事务

 // 原有参数、身份校验逻辑保留
 foreach ($option_ids as $option_id) {
 // 新增投票记录
 $stmt = $db->prepare("INSERT INTO poll_votes (poll_id, option_id, user_id)
VALUES (?, ?, ?)");
 $stmt->execute([$poll_id, $option_id, $user_id]);
 // 票数自增
 $stmt = $db->prepare("UPDATE poll_options SET vote_count = vote_count
+ 1 WHERE id = ?");
 $stmt->execute([$option_id]);
 }

 $db->commit(); // 全部执行成功再提交
 echo json_encode(['status' => 'success', 'message' => '投票成功']);

} catch (Exception $e) {
 $db->rollBack(); // 出错全部回滚
}
```

```

 echo json_encode(['status' => 'error', 'message' => '服务器错误']);
 }
 ...

```

中等问题 1: create\_poll.php 登录会话判断逻辑混乱

文件位置: create\_poll.php 6~11 行

问题描述: 区分普通用户/管理员的登录校验逻辑不统一, 管理员账号无 user\_id 会判定未登录。

优化校验代码:

```

```php
$is_admin = isset($_SESSION['is_admin']) && $_SESSION['is_admin'];
$current_user_id = $is_admin ? $_SESSION['admin_id'] : $_SESSION['user_id'];

if (empty($current_user_id)) {
    echo json_encode(['success' => false, 'message' => '请先登录']);
    exit;
}
...

```

中等问题 2: admin_polls.php 不支持图片类投票选项

文件位置: admin_polls.php 89~107 行

问题描述: 创建投票数据表、选项插入语句仅存储文字, 未对接图片字段与投票类型字段。

优化 SQL 插入代码:

```

```php
// 投票主表新增 option_type 字段写入
$stmt = $db->prepare("INSERT INTO polls (title, description, topic, creator_id,
is_multiple, max_options, end_time, is_active, is_anonymous, option_type) VALUES
(?, ?, ?, ?, ?, ?, ?, ?, ?, ?)");
$stmt->execute([
 $input['title'],
 $input['description'] ?? "",
 $input['topic'] ?? "",
 $_SESSION['admin_id'],
 $input['is_multiple'] ?? 0,
 $input['max_options'] ?? 1,
 $input['end_time'] ?? null,
 $input['is_active'] ?? 1,
 $input['is_anonymous'] ?? 0,
 $input['option_type'] ?? 'text'
]);

// 选项支持图片存储
$stmt = $db->prepare("INSERT INTO poll_options (poll_id, option_text, option_image)

```

```
VALUES (?, ?, ?)");
foreach ($validOptions as $option) {
 if (is_array($option)) {
 $stmt->execute([$pollId, $option['text'], $option['image']]);
 } else {
 $stmt->execute([$pollId, trim($option), null]);
 }
}
...

```

中等问题 3: get\_polls.php 循环查询造成 N+1 性能问题

文件位置: get\_polls.php 42~73 行

问题描述: 先查出全部投票, 再循环逐个查每个投票的选项, 数据库请求次数翻倍, 数据量大时卡顿。

优化方案: 批量 IN 查询一次性取出所有选项, 内存分组绑定:

```
```php
// 1. 查询全部投票列表
$stmt = $db->prepare($sql);
$stmt->execute($params);
$polls = $stmt->fetchAll(PDO::FETCH_ASSOC);

$pollIds = array_column($polls, 'id');
if (!empty($pollIds)) {
    // 2. 一次性批量查询所有投票对应的选项
    $placeholders = implode(',', array_fill(0, count($pollIds), '?'));
    $stmt = $db->prepare("SELECT poll_id, id, option_text, option_image,
vote_count FROM poll_options WHERE poll_id IN ($placeholders) ORDER BY poll_id,
id");
    $stmt->execute($pollIds);
    $allOptions = $stmt->fetchAll(PDO::FETCH_ASSOC);

    // 3. 按投票 ID 分组
    $optionsMap = [];
    foreach ($allOptions as $opt) {
        $optionsMap[$opt['poll_id']][] = $opt;
    }

    // 4. 绑定到对应投票数据
    foreach ($polls as &$poll) {
        $poll['options'] = $optionsMap[$poll['id']] ?? [];
    }
}
...
```

```

中等问题 4: db.php 使用 die()终止程序不规范

文件位置: db.php 第 47 行

问题描述: 数据库连接失败直接 die()粗暴终止, 无日志记录、无标准 500 返回码。

优化错误处理:

```
```php
} catch (PDOException $e) {
    Logger::error('数据库连接失败', ['error' => $e->getMessage()]);
    http_response_code(500);
    echo json_encode(['status' => 'error', 'message' => '数据库连接失败']);
    exit;
}
```
```

低危优化 1: logger.php 无日志自动清理轮转

文件位置: logger.php 28~50 行

问题描述: 日志按天生成文件, 无过期清理, 长期运行堆积大量日志占用磁盘。

新增自动清理方法 (保留 30 天日志):

```
```php
private static function cleanOldLogs() {
    $logPath = Env::get('LOG_PATH', 'logs/');
    $maxSaveDays = 30;
    $expireTimestamp = time() - ($maxSaveDays * 24 * 60 * 60);

    foreach (glob("$logPathapp_.log") as $file) {
        if (filemtime($file) < $expireTimestamp) {
            unlink($file);
        }
    }
}
```
```

低危优化 2: 全项目 API 返回格式不统一

问题说明: 不同接口返回键名不一致, 前端适配繁琐

- create\_poll.php: `{"success":布尔,"message":文本}`  
- vote.php: `{"status":"success/error","message":文本}`  
- get\_polls.php: `{"success":布尔,"data":数组}`

统一标准返回结构 (推荐全局复用):

```
```json
{
    "status": "success",
    "message": "操作提示文案",
    "data": {}
}
```

```
}  
...
```

低危优化 3: create_poll.js 前端 DOM 逻辑重复冗余

文件位置: static/js/create_poll.js

问题描述: 新增文本/图片选项的 DOM 创建、删除逻辑重复, 无封装通用函数。

抽取通用创建工具函数:

```
``javascript  
// 统一生成选项 DOM  
function createOptionItem(type, index, textValue = '') {  
    const div = document.createElement('div');  
    div.className = type === 'text' ? 'option-item' : 'image-option-item';  
  
    if (type === 'text') {  
        div.innerHTML = `  
            <input type="text" class="option-input" placeholder="请输入第  
${index + 1}项 (35 个字以内)" required maxlength="35" value="${textValue}">  
            <button type="button" class="btn btn-danger remove-option">删除  
</button>  
        `;  
    } else {  
        div.innerHTML = `  
            <div class="image-upload-area" onclick="triggerImageUpload(this)">  
                <input type="file" class="image-file" accept="image/"  
onchange="handleImageUpload(this)" style="display: none;">  
                <span class="upload-icon">+</span>  
                <span class="upload-text">添加图片</span>  
            </div>  
            <input type="text" class="option-input" placeholder="请输入选项文  
字" maxlength="35" value="${textValue}">  
            <button type="button" class="btn btn-danger remove-option">删除  
</button>  
        `;  
    }  
    // 绑定删除按钮事件  
    setupRemoveOption(div.querySelector('.remove-option'));  
    return div;  
}  
...
```

低危优化 4: env.php 环境变量读取缺少类型保护

文件位置: config/env.php

问题描述: 读取配置未做数值类型转换, 读取数字配置会返回字符串。

优化 get 方法:

```

```php
public static function get($key, $default = null) {
 $value = isset(self::$vars[$key]) ? self::$vars[$key] : $default;
 // 自动转换数字类型配置
 if (is_numeric($value)) {
 return intval($value);
 }
 return $value;
}
```

```

四、整改优先级清单

第一阶段：紧急修复（高危 2 项，1~2 小时完成）

1. 移除 admin 接口错误返回中的 session 字段，防止信息泄露
2. 投票接口增加数据库事务，避免数据不一致

第二阶段：功能&性能优化（中等 4 项，2~3 小时完成）

1. 统一登录会话校验逻辑，区分管理员/普通用户身份
2. 后台创建投票支持图片选项入库
3. 重构投票列表查询，解决 N+1 循环查询性能问题
4. 数据库异常统一使用 exit，替换 die()，增加日志记录

第三阶段：代码重构规范（低危 4 项，3~4 小时完成）

1. 封装统一 API 返回格式，全项目统一使用
2. 前端 JS 抽取通用 DOM 工具函数，消除重复代码
3. 环境变量读取增加数值类型自动转换
4. 日志类增加定时清理过期日志方法

第四阶段：工程化完善（拓展优化，4~6 小时）

新增单元测试、CI/CD 自动部署、全局公共工具类、接口文档等配套工程化能力

五、总结

1. 本次代码审查共检出 10 项问题：2 高危、4 中等、4 低危优化；
2. 项目整体目录分层清晰、基础防 SQL 注入措施到位，但安全、数据一致性存在硬伤，必须优先修复；
3. 长期可通过统一返回格式、封装公共工具、日志轮转、批量查询优化进一步提升系统稳定性、可维护性。